Mini-projet 1 : Fondamentaux et Identification/Authentification

> Author: Badr TAJINI - Information Systems Security - ECE 2025-2026

Roadmap

- **Contenu Théorique:**
  - Introduction à la sécurité (CIA triad, Parkerian hexad, risques, menaces, vulnérabilités, contrôle, incident response).
  - Identification et authentification (facteurs, MFA, authentification mutuelle).
- **Labs:**
  - Mise en place de l'environnement de travail (VM Kali Linux). - `(Partie 1A)`
  - Mise en place d'une politique de mot de passe (complexité, renouvellement). - `(Partie 1B)`
  - Configuration de l'authentification SSH avec échange de clés. - `(Partie 1C)`
  - Introduction aux outils d'attaque et de test (Wireshark, Nmap, etc). - `(Partie 1D)`
  - Mise en place de protection basique (exemple : firewall basique). - `(Partie 1E)`
- **Objectifs:**
  - Comprendre les concepts fondamentaux de la sécurité.
  - Mettre en place des systèmes d'authentification basique sur les machines.
  - Se familiariser avec les outils (Wireshark, Nmap).
  - Découvrir comment mettre en place des règles de firewall simples pour comprendre le fonctionnement.

> [!IMPORTANT]
>
> **Note :** la Roadmap représente une serie de scripts qui peuvent potentiellement vous aider et vous guider. Vous avez le libre choix d'ajouter/supprimer/améliorer/debugger les scripts proposés.

Partie 1A : Mise en place de l'environnement de travail (VM Kali Linux)

Objectif : Mettre en place un environnement de laboratoire en utilisant Kali Linux. Plusieurs options sont disponibles selon votre système d'exploitation.

Options pour l'environnement de travail :

1. **Machine Virtuelle avec VirtualBox (Recommandé - Multiplateforme et Isolation) :** Solution recommandée pour une isolation maximale et une expérience cohérente quel que soit votre système d'exploitation (Windows, macOS, Linux).
2. **WSL2 (Windows Subsystem for Linux version 2) (Windows uniquement - Intégration Système) :** Option pour les utilisateurs de Windows 10/11 qui souhaitent une intégration plus directe avec leur système hôte. Moins d'isolation qu'une VM complète.
3. **Machine Virtuelle avec Parallels Desktop (macOS uniquement - Performance et Intégration) :** Option pour les utilisateurs de macOS utilisant Parallels Desktop. Offre de bonnes performances et une intégration avec macOS. (Parallels Desktop est un logiciel commercial).

Choisissez l'option qui correspond le mieux à votre système d'exploitation et à vos préférences.

Option 1 : Machine Virtuelle avec VirtualBox (Instructions Détaillées)

> (Suivez ces instructions si vous choisissez VirtualBox. Si vous choisissez WSL ou Parallels, passez à la section correspondante.)

1. **Installation de VirtualBox :**
   - Téléchargez et installez VirtualBox (Oracle VM VirtualBox) à partir du site officiel : https://www.virtualbox.org/
   - Choisissez la version correspondant à votre système d'exploitation (Windows, macOS, Linux).
2. **Téléchargement de l'Image ISO de Kali Linux :**
   - Téléchargez l'image ISO de Kali Linux pour "Virtual Machines" depuis le site officiel : https://www.kali.org/downloads/
   - Choisissez la version "Kali Linux 64-Bit (VMware & VirtualBox)".
3. **Création de la Machine Virtuelle dans VirtualBox :**
   - Ouvrez VirtualBox et cliquez sur "Nouvelle" (New).
   - **Nom :** `Kali-CyberSec-Lab-VB` (par exemple).
   - **Type :** Linux
   - **Version :** Debian (64-bit)
   - **Mémoire Vive (RAM) :** Minimum 4 Go (4096 Mo), 8 Go recommandés si possible.
   - **Disque Dur Virtuel :**
     - "Créer un disque dur virtuel maintenant".
     - **Type de fichier de disque dur :** VDI (VirtualBox Disk Image).
     - **Stockage sur disque physique :** "Dynamiquement alloué".
     - **Taille :** Minimum 30 Go.
   - Cliquez sur "Créer".
4. **Configuration des Paramètres Réseau de la VM VirtualBox :**
   - Sélectionnez la VM `Kali-CyberSec-Lab-VB` et cliquez sur "Configuration" (Settings).
   - Allez dans l'onglet "Réseau" (Network).
   - **Attaché à :** Choisissez "Réseau interne" (Internal Network).
     - Si "Réseau interne" n'est pas disponible, créez-le : "Fichier" -> "Gestionnaire de réseau hôte seul" -> "Créer".
   - Cliquez sur "OK".
5. **Installation de Kali Linux dans la VM VirtualBox :**
   - Sélectionnez la VM et cliquez sur "Démarrer" (Start).
   - Sélectionnez l'ISO de Kali Linux comme disque de démarrage.
   - Choisissez "Graphical install" au démarrage de Kali Linux.
   - Suivez les instructions d'installation (langue, clavier, nom d'hôte `kali-lab-vb`, nom d'utilisateur `etudiant` **(ou autre nom)**, mot de passe fort, partitionnement assisté, etc.).

Option 2 : WSL2 (Windows Subsystem for Linux version 2) (Instructions Détaillées pour Windows 10/11)

> (Suivez ces instructions si vous choisissez WSL2. Si vous avez choisi VirtualBox ou Parallels, ignorez cette section.)

1. **Activation de WSL2 et Virtualisation :**
   - Assurez-vous que la virtualisation est activée dans le BIOS/UEFI de votre ordinateur (consultez la documentation de votre fabricant si nécessaire).
   - Ouvrez PowerShell en tant qu'administrateur et exécutez :

     ```
     Enable-WindowsOptionalFeature -Online -FeatureName Microsoft-Windows-Subsystem-Linux
     dism.exe /online /enable-feature /featurename:VirtualMachinePlatform /all /norestart
     ```

   - Redémarrez votre ordinateur.
   - Après redémarrage, ouvrez PowerShell en tant qu'administrateur et définissez WSL2 comme version par défaut :

     ```
     wsl --set-default-version 2
     ```

2. **Installation de Kali Linux dans WSL2 via Microsoft Store :**
   - Ouvrez le Microsoft Store et recherchez "Kali Linux".
   - Installez l'application "Kali Linux".
   - Après l'installation, lancez "Kali Linux" depuis le menu Démarrer.
   - La première exécution peut prendre quelques minutes pour l'installation.
   - Créez un nouvel utilisateur Linux et un mot de passe lorsque vous y êtes invité (nom d'utilisateur `etudiant` **(ou autre nom)**, mot de passe fort).

Option 3 : Machine Virtuelle avec Parallels Desktop (Instructions Détaillées pour macOS)

> (Suivez ces instructions si vous choisissez Parallels Desktop. Si vous avez choisi VirtualBox ou WSL, ignorez cette section.)

1. **Installation de Parallels Desktop (si non déjà installé) :**
   - Si Parallels Desktop n'est pas installé, suivez les instructions d'installation fournies par Parallels. (Parallels Desktop est un logiciel commercial et nécessite une licence).

2. **Téléchargement de l'Image ISO de Kali Linux (si nécessaire) :**
   - Si vous n'avez pas déjà l'ISO de Kali Linux, téléchargez-la pour "Virtual Machines" depuis : https://www.kali.org/downloads/
   - Choisissez la version "Kali Linux 64-Bit (VMware & VirtualBox)".

3. **Création d'une Nouvelle Machine Virtuelle Kali Linux dans Parallels Desktop :**
    - Ouvrez Parallels Desktop et cliquez sur "Fichier" -> "Nouveau".
    - Vous pouvez avoir plusieurs options :
        - **"Installer Windows ou un autre OS depuis un DVD ou un fichier image" :** Choisissez cette option et sélectionnez l'ISO de Kali Linux téléchargée.
        - Parallels peut aussi proposer des distributions Linux préconfigurées. Si Kali Linux est proposé, vous pouvez le sélectionner.
    - Suivez les instructions de Parallels pour créer la VM.
    - Configurez les ressources de la VM :
        - **Nom :** `Kali-CyberSec-Lab-PD` (par exemple).
        - **Mémoire :** Minimum 4 Go, 8 Go recommandés.
        - **Processeurs :** Au moins 2 CPU virtuels.
        - **Disque Dur :** Par défaut, Parallels crée un disque virtuel. Assurez-vous d'avoir au moins 30 Go d'espace disponible.
    - Continuez l'installation de Kali Linux dans Parallels, en suivant les instructions d'installation standard de Kali Linux (langue, clavier, nom d'hôte `kali-lab-pd`, nom d'utilisateur `etudiant` **(ou autre nom)**, mot de passe fort, etc.).

Étapes Communes Après l'Installation (Valable pour VirtualBox, WSL2 et Parallels Desktop)

1. **Premier Démarrage et Connexion à Kali Linux :**
    - Démarrez votre VM Kali Linux (ou lancez l'application Kali Linux sous WSL2).
    - Connectez-vous avec le nom d'utilisateur (`etudiant`) **(ou autre nom)** et le mot de passe que vous avez créés lors de l'installation.

2. **Configuration Réseau (Si nécessaire et selon l'option choisie) :**
    - **VirtualBox :** Le "Réseau interne" devrait être configuré. Vérifiez que la VM n'a pas d'accès internet direct (ce qui est normal en réseau interne).
    - **WSL2 :** WSL2 partage la connexion réseau de votre machine Windows hôte. Vous devriez avoir un accès internet depuis Kali Linux sous WSL2.
    - **Parallels Desktop :** Par défaut, Parallels configure souvent le réseau en mode "Réseau partagé" (NAT), ce qui permet à la VM d'accéder à internet via la connexion macOS hôte. Pour des labs isolés, vous pouvez configurer un "Réseau privé hébergé" dans les paramètres réseau de la VM Parallels.

Vérification :

- Assurez-vous que Kali Linux démarre correctement et que vous pouvez vous connecter.
- Vérifiez la configuration réseau selon l'option choisie et les besoins des parties à venir.

Partie 1B : Mise en place d'une politique de mot de passe (complexité, renouvellement)

Objectif : L'objectif de cette partie est de comprendre et de mettre en œuvre une politique de mot de passe robuste sur un système Linux. Vous apprendrez à configurer les exigences de complexité des mots de passe, les règles de renouvellement, et à tester l'application de ces politiques.

Étapes pour la mise en place d'une politique de mot de passe :

1. **Connexion à la VM Kali Linux (ou Ubuntu) :**
   - Démarrez votre VM Kali Linux (ou Ubuntu) et connectez-vous avec votre compte utilisateur (celui que vous avez créé lors de l'installation, par exemple `etudiant` **(ou autre nom)**).
   - Ouvrez un terminal.
2. **Compréhension théorique : politiques de mot de passe**
   - **Importance des mots de passe forts :** Les mots de passe sont la première ligne de défense pour l'accès à un système. Des mots de passe faibles sont facilement compromis par des attaques de force brute ou de dictionnaire.
   - **Politique de complexité :** Une politique de complexité définit les critères qu'un mot de passe doit respecter. Cela inclut généralement :
     - **Longueur minimale :** Nombre minimum de caractères (ex: 12 caractères ou plus recommandés aujourd'hui).
     - **Types de caractères :** Combinaison de majuscules, minuscules, chiffres, et caractères spéciaux.
   - **Politique de renouvellement (Expiration) :** Le renouvellement périodique des mots de passe (expiration) est une mesure pour limiter la durée de validité d'un mot de passe compromis potentiel et encourager les utilisateurs à changer régulièrement leurs mots de passe. Cependant, il faut noter que le renouvellement forcé seul, sans complexité, peut mener à des mots de passe complexes *mais prévisibles* (basés sur des schémas). L'idéal est de combiner complexité et renouvellement *judicieux*.
   - **Outils Linux pour la Gestion des Politiques de Mot de Passe :** Sous Linux, l'outil principal pour gérer les politiques de mot de passe est `pam_pwquality` (ou `pwquality`). PAM (Pluggable Authentication Modules) est un système qui permet de gérer l'authentification de manière modulaire. `pam_pwquality` est un module PAM qui applique des règles de qualité aux mots de passe.
3. **Installation du Module `pwquality` (si nécessaire) :**
   - Sur Kali Linux, `pwquality` est généralement préinstallé. Sur Ubuntu Server, il peut être nécessaire de l'installer.
   - Pour installer `pwquality` sur Ubuntu (ou vérifier sur Kali) :

     ```
     sudo apt update
     sudo apt install libpwquality-tools
     sudo apt install libpam-pwquality
     ```
4. **Configuration de la Politique de Mot de Passe avec `pwquality` :**
   - Le fichier de configuration principal pour `pwquality` est `/etc/security/pwquality.conf`.
   - Utilisez un éditeur de texte en ligne de commande (comme `nano` ou `vim`) avec les privilèges administrateur pour modifier ce fichier :

```
sudo nano /etc/security/pwquality.conf
```

- **Paramètres importants à configurer :**
  - `minlen = 12` : Définit la longueur minimale du mot de passe à 12 caractères. *Explication : Une longueur plus importante rend les attaques par force brute beaucoup plus difficiles.*
  - `minclass = 4` : Exige d'utiliser au moins 4 classes de caractères (minuscules, majuscules, chiffres, spéciaux). *Explication : Augmente la complexité et la robustesse du mot de passe.*
  - `ucredit = -1` : Exige au moins une majuscule (u pour uppercase, -1 signifie au moins une). *Explication : Force l'utilisation de majuscules.*
  - `lcredit = -1` : Exige au moins une minuscule (l pour lowercase). *Explication : Force l'utilisation de minuscules.*
  - `dcredit = -1` : Exige au moins un chiffre (d pour digit). *Explication : Force l'utilisation de chiffres.*
  - `ocredit = -1` : Exige au moins un caractère spécial (o pour other). *Explication : Force l'utilisation de caractères spéciaux.*
  - `maxrepeat = 3` : Limite le nombre de caractères identiques consécutifs à 3. *Explication : Empêche les mots de passe trop simples comme "aaaa1234".*
  - `maxsequence = 3` : Limite les séquences de caractères (alphabétiques ou numériques) à 3. *Explication : Empêche les séquences comme "abc" ou "123".*
  - `difok = 5` : Exige qu'au moins 5 caractères du nouveau mot de passe soient différents de l'ancien mot de passe. *Explication : Empêche la réutilisation facile ou des modifications mineures de l'ancien mot de passe.*
  - `gecoscheck = 1` : Vérifie si le nouveau mot de passe ne contient pas d'informations du champ GECOS (informations personnelles de l'utilisateur, comme le nom). *Explication : Empêche l'utilisation d'informations personnelles facilement devinables.*
- **Exemple de configuration `/etc/security/pwquality.conf` :**

```
minlen = 12
minclass = 4
ucredit = -1
lcredit = -1
dcredit = -1
ocredit = -1
maxrepeat = 3
maxsequence = 3
difok = 5
gecoscheck = 1
```

- **Sauvegardez les modifications** dans `nano` (Ctrl+X, puis O pour Oui, puis Entrée).

5. **Application de la Politique de Mot de Passe via PAM :**
   - Il faut maintenant dire à PAM d'utiliser le module `pwquality` lors du changement de mot de passe. Ceci se configure dans les fichiers de configuration PAM.

- Le fichier à modifier est généralement `/etc/pam.d/common-password`.
- Ouvrez ce fichier avec les privilèges administrateur :

```
sudo nano /etc/pam.d/common-password
```

- **Localisez la ligne** qui ressemble à :

```
password    required     pam_unix.so ...
```

- **Ajoutez `pam_pwquality.so`** *avant* `pam_unix.so` et *après* `pam_deny.so` (si présent), et ajustez les options pour `pam_unix.so` pour qu'il ne fasse pas de vérification de complexité (car `pam_pwquality.so` le fera). La ligne modifiée devrait ressembler à (les options de `pam_unix.so` peuvent varier légèrement selon votre système) :

```
password    requisite   pam_pwquality.so retry=3
password    required    pam_unix.so sha512 shadow nullok try_first_pass
use_authtok
```

  - `requisite pam_pwquality.so retry=3` : Indique à PAM d'exécuter `pam_pwquality.so`. `requisite` signifie que si ce module échoue, l'authentification échoue immédiatement. `retry=3` permet à l'utilisateur de réessayer 3 fois de saisir un mot de passe valide avant d'abandonner.
  - `required pam_unix.so ...` : Le module `pam_unix.so` est toujours nécessaire pour gérer les mots de passe Unix traditionnels. Les options `sha512 shadow nullok try_first_pass use_authtok` sont des options courantes pour ce module et peuvent être conservées.
  - Normalement, le fichier complet est comme ci-dessous :

```
# /etc/pam.d/common-password - password-related modules common to
all services
# ... (autres commentaires en haut du fichier) ...

# here are the per-package modules (the "Primary" block)
password        requisite                       pam_pwquality.so
retry=3
password        required                        pam_unix.so sha512
shadow nullok try_first_pass use_authtok

# here's the fallback if no module succeeds
#password        required                        pam_deny.so
(devrait être commenté ou absent) <===

# prime the stack with a positive return value if there isn't one
```

```
already;
# this avoids us returning an error just because nothing sets a
success code
# since the modules above will each just jump around
password        required                        pam_permit.so #
(devrait être commenté ou absent) <===

# and here are more per-package modules (the "Additional" block)
password        optional
pam_gnome_keyring.so # (devrait être commenté ou absent) <===

# end of pam-auth-update config
```

- **Sauvegardez les modifications** dans `/etc/pam.d/common-password`.

6. **Configuration du Renouvellement de Mot de Passe (Expiration) :**

   - Le renouvellement des mots de passe est géré par l'outil `chage`. On peut définir une politique d'expiration par défaut pour tous les nouveaux utilisateurs, ou modifier les paramètres pour un utilisateur existant.

   - **Politique d'expiration par défaut (pour les nouveaux utilisateurs) :** Modifiez le fichier `/etc/login.defs`.

     ```
     sudo nano /etc/login.defs
     ```

     - **Recherchez les lignes** commençant par `PASS_MAX_DAYS`.
     - **Décommentez et modifiez** `PASS_MAX_DAYS` pour définir la durée de validité maximale du mot de passe en jours (ex: 90 jours) :

       ```
       PASS_MAX_DAYS   90
       ```

     - Vous pouvez aussi configurer `PASS_MIN_DAYS` (nombre minimum de jours avant de pouvoir changer le mot de passe), `PASS_WARN_AGE` (nombre de jours avant expiration pour commencer à avertir l'utilisateur), etc. Consultez la documentation de `login.defs` pour plus de détails (`man login.defs`).
     - **Sauvegardez les modifications** dans `/etc/login.defs`.

   - **Modifier la politique pour un utilisateur existant (ex: `etudiant` (ou autre nom)) :** Utilisez la commande `chage`.

     - Pour voir la politique actuelle pour l'utilisateur `etudiant` **(ou autre nom)** :

       ```
       sudo chage -l etudiant
       ```

    - Pour définir une expiration maximale de 90 jours pour l'utilisateur `etudiant` **(ou autre nom)** :

      ```
      sudo chage -M 90 etudiant
      ```

      (`-M` pour Max days between password change)
    - Consultez `man chage` pour plus d'options.

7. **Test de la Politique de Mot de Passe :**

    - **Changez le mot de passe de l'utilisateur `etudiant` (ou autre nom) :**

      ```
      passwd etudiant
      ```

    - **Testez différents mots de passe :**
      - Essayez un mot de passe trop court (ex: "court"). Vous devriez recevoir un message d'erreur indiquant que le mot de passe est trop court.
      - Essayez un mot de passe sans chiffres (ex: "MotDePasseComplexe"). Vous devriez recevoir un message d'erreur indiquant qu'il manque des chiffres.
      - Essayez un mot de passe qui ne respecte pas toutes les règles de complexité que vous avez définies dans `/etc/security/pwquality.conf`. Vérifiez que les messages d'erreur correspondent aux règles que vous avez configurées.
      - Essayez un mot de passe qui respecte *toutes* les règles de complexité (ex: "M@tDeP@$$3_Compl3xe!"). Le mot de passe devrait être accepté.
    - **Vérifiez l'expiration du mot de passe (si vous avez configuré `PASS_MAX_DAYS` ou `chage -M`) :** La politique d'expiration prendra effet pour les *nouveaux* mots de passe après la date de dernière modification. Pour tester immédiatement, vous pouvez forcer l'expiration du mot de passe actuel de l'utilisateur `etudiant` **(ou autre nom)** avec :

      ```
      sudo chage -d 0 etudiant
      ```

      (`-d 0` met la date de dernière modification à 0, ce qui force l'expiration immédiate).
      - La prochaine fois que l'utilisateur `etudiant` **(ou autre nom)** se connectera (par SSH ou directement dans la console de la VM), il devrait être invité à changer son mot de passe.

Résolution de Problèmes :

- **Si la politique de mot de passe ne semble pas appliquée :**
    - Vérifiez que vous avez bien modifié les fichiers `/etc/security/pwquality.conf` et `/etc/pam.d/common-password` *avec les privilèges administrateur* (en utilisant `sudo`).
    - Vérifiez la syntaxe des fichiers de configuration. Une erreur de syntaxe peut empêcher l'application des règles.
    - Redémarrez la VM (parfois un redémarrage complet de la VM est nécessaire pour que les changements PAM soient complètement pris en compte).

- Consultez les logs système (ex: `/var/log/auth.log` ou `/var/log/secure` selon la distribution) pour voir s'il y a des messages d'erreur liés à PAM ou à `pwquality` lors du changement de mot de passe.

Partie 1C : Configuration de l'authentification SSH avec échange de clés

Objectif : Sécuriser l'accès SSH en utilisant l'authentification par clé publique et désactiver l'authentification par mot de passe. L'authentification par clé est plus robuste contre les attaques par force brute et dictionnaire.

Prérequis : Deux VMs Linux : une Kali Linux (client SSH) et une Ubuntu (serveur SSH). Assurez-vous de leur connectivité réseau.

Étapes :

1. **Générer la paire de clés SSH (sur la VM Kali - client) :**
   - Ouvrez un terminal sur Kali Linux.
   - Exécutez la commande suivante :

     ```
     ssh-keygen
     ```

   - Acceptez l'emplacement par défaut pour enregistrer la clé (appuyez sur Entrée).
   - **Important :** Définissez une *phrase secrète* (passphrase) pour protéger la clé privée. Si compromise sans passphrase, l'accès est direct.

2. **Copier la clé publique vers le serveur (VM Ubuntu) en utilisant `ssh-copy-id` :**
   - Sur Kali Linux, exécutez la commande suivante :

     ```
     ssh-copy-id utilisateur@adresse_ip_ubuntu
     ```

     (remplacez `utilisateur` par le nom d'utilisateur sur la VM Ubuntu et `adresse_ip_ubuntu` par l'adresse IP de la VM Ubuntu).

   - Saisissez le mot de passe de l'utilisateur sur Ubuntu lorsque demandé. `ssh-copy-id` configure automatiquement l'authentification par clé sur Ubuntu.
   - *Alternative manuelle (si `ssh-copy-id` indisponible) :*
     - Sur Kali Linux, exécutez pour afficher et copier la clé publique :

       ```
       cat ~/.ssh/id_rsa.pub
       ```

     - Sur Ubuntu (via SSH avec mot de passe), exécutez les commandes suivantes :

```
mkdir -p ~/.ssh
chmod 700 ~/.ssh
nano ~/.ssh/authorized_keys
```

(Collez la clé publique dans `nano` et enregistrez le fichier).

```
chmod 600 ~/.ssh/authorized_keys
```

3. **Tester la connexion SSH par clé :**
   - Sur Kali Linux, exécutez la commande suivante :

     ```
     ssh utilisateur@adresse_ip_ubuntu
     ```

     (remplacez `utilisateur` et `adresse_ip_ubuntu`).
   - Si vous avez défini une phrase secrète, elle sera demandée. Sinon, la connexion devrait être immédiate.
4. **Désactiver l'authentification par mot de passe sur le serveur SSH (VM Ubuntu) :**
   - Sur Ubuntu, éditez le fichier de configuration SSH :

     ```
     sudo nano /etc/ssh/sshd_config
     ```

   - Modifiez la ligne `PasswordAuthentication yes` en `PasswordAuthentication no`.
   - Redémarrez le service SSH :

     ```
     sudo systemctl restart sshd
     ```

5. **Vérifier la désactivation du mot de passe :**
   - Depuis Kali Linux, tentez de vous reconnecter par SSH :

     ```
     ssh utilisateur@adresse_ip_ubuntu
     ```

     La connexion par clé doit toujours fonctionner.
   - Tentez une connexion *forcée* par mot de passe (devrait échouer) :

     ```
     ssh -o PreferredAuthentications=password utilisateur@adresse_ip_ubuntu
     ```

La connexion devrait être refusée.

Partie 1D : Introduction aux outils d'attaque et de test (Wireshark, Nmap, etc.)

Objectif : Familiarisation avec quelques outils fondamentaux utilisés en cybersécurité pour l'analyse réseau, la découverte de services, et les tests d'intrusion. Cette partie vise à donner une première prise en main de Wireshark et Nmap, deux outils *incontournables* pour tout professionnel de la sécurité. L'idée est de comprendre leur rôle et de réaliser des manipulations simples.

Outils Présentés :

1. **Wireshark : Analyseur de Protocole Réseau (Sniffer)**
   - **Rôle :** Wireshark est un analyseur de protocole réseau (aussi appelé "sniffer"). Il capture le trafic réseau en temps réel et permet de l'analyser en détail. C'est un outil *essentiel* pour comprendre ce qui se passe sur un réseau, diagnostiquer des problèmes, analyser des communications suspectes, et étudier les protocoles réseau.
   - **Interface :** Wireshark possède une interface graphique (GUI) et une version en ligne de commande (`tshark`). Pour cette partie d'introduction, nous nous concentrerons sur l'interface graphique.
   - **Cas d'utilisation typiques en cybersécurité :**
     - Analyse du trafic réseau lors d'une attaque pour comprendre le déroulement et les protocoles utilisés.
     - Débogage de problèmes de communication réseau.
     - Analyse de fichiers de capture réseau (pcap) pour investiguer des incidents de sécurité.
     - Étude des échanges de données entre une application et un serveur web.

2. **Nmap : Scanner de Ports et Découverte de Services**
   - **Rôle :** Nmap ("Network Mapper") est un scanner de ports puissant et flexible. Il permet de découvrir les hôtes actifs sur un réseau, les ports ouverts sur ces hôtes, les services qui tournent sur ces ports, le système d'exploitation utilisé par les hôtes, et bien plus. Nmap est un outil *fondamental* pour la reconnaissance réseau et l'évaluation de la posture de sécurité d'un système ou d'un réseau.
   - **Interface :** Nmap est principalement utilisé en ligne de commande, mais il existe aussi une interface graphique moins courante (`Zenmap`). Nous utiliserons la ligne de commande pour ce lab.
   - **Cas d'utilisation typiques en cybersécurité :**
     - Découverte des services actifs sur un serveur avant de tenter de les exploiter.
     - Inventaire des équipements et services sur un réseau.
     - Identification de vulnérabilités potentielles (services obsolètes, ports ouverts non nécessaires).
     - Tests de pénétration (pentesting) pour évaluer la sécurité d'un réseau.

> [!IMPORTANT]

> **Options de VMs :**
>
> Je recommande **"Deux VMs Kali Linux et une VM Ubuntu"** pour les raisons suivantes :
>
> - **Rôle des VMs :** On peut désigner l'une des VMs Kali comme "Attaquant" et l'autre comme "Analyseur" (pour Wireshark par exemple), tandis que la VM Ubuntu servira de "Victime". Cela donne un rôle plus défini à chaque VM.
> - **Gestion des Ressources :** Deux VMs Kali suffisent pour la plupart des mini-projets, et une VM Ubuntu légère n'est pas trop gourmande.

Prise en Main :

1. **Wireshark - Capture et Analyse de Base (sur la VM Analyseur Kali Linux) :**
   - **Lancement de Wireshark :** Ouvrez Wireshark depuis le menu des applications de Kali Linux (ou en tapant la commande suivante dans un terminal et en lançant avec `sudo` si nécessaire) :

     ```
     wireshark
     ```

   - **Sélection de l'interface de capture :** Wireshark affiche une liste des interfaces réseau disponibles. Choisissez l'interface réseau connectée à votre réseau interne (par exemple `eth0` ou `enp0s3`). Cliquez sur l'icône de capture (l'aileron de requin bleu) ou double-cliquez sur l'interface.
   - **Début de la capture :** Wireshark commence à capturer le trafic réseau. Vous verrez défiler une liste de paquets en temps réel.
   - **Générer du trafic réseau (depuis une autre VM ou la VM Kali elle-même) :**
     - Ouvrez un terminal sur la VM **Victime Ubuntu** (ou sur la VM **Attaquant Kali Linux**).
     - Utilisez la commande `ping` pour envoyer des paquets ICMP vers une autre machine sur le réseau interne (par exemple, la VM Ubuntu si vous êtes sur Kali Attaquant, ou vice versa). Remplacez `adresse_ip_cible` par l'adresse IP de la machine cible :

       ```
       ping -c 5 adresse_ip_cible
       ```

       `-c 5` envoie seulement 5 paquets ping pour limiter le trafic.
     - Vous devriez voir apparaître des paquets ICMP dans la fenêtre de Wireshark sur la VM **Analyseur Kali Linux**.
   - **Arrêt de la capture :** Cliquez sur le bouton "Stop" (carré rouge) dans Wireshark pour arrêter la capture.
   - **Filtrage du trafic :** Dans la barre de filtre de Wireshark (au-dessus de la liste des paquets), tapez `icmp` et appuyez sur Entrée. Wireshark affichera seulement les paquets ICMP capturés.
     Explication : Les filtres sont très puissants dans Wireshark pour se concentrer sur le trafic pertinent.
   - **Analyse d'un paquet :** Sélectionnez un paquet ICMP dans la liste. Vous verrez trois panneaux en dessous :
     - **Frame details :** Détails bruts de la trame Ethernet.
     - **Packet details :** Détails décodés du paquet, par couches de protocoles (Ethernet, IP, ICMP...). Explorez les différents champs.

        - **Packet bytes :** Représentation hexadécimale et ASCII des données brutes du paquet.
    - **Exercice :** Identifiez l'adresse IP source et destination des paquets ICMP, le type de message ICMP (request ou reply), etc.

2. **Nmap - Scan de Ports de Base (sur la VM Attaquant Kali Linux) :**

    - **Scan de ports TCP SYN :** Sur la VM **Attaquant Kali Linux**, ouvrez un terminal. Utilisez Nmap pour scanner les ports TCP de la VM **Victime Ubuntu**. Remplacez `adresse_ip_victime` par l'adresse IP de la VM Ubuntu :

        ```
        nmap -sS adresse_ip_victime
        ```

        `-sS` spécifie un scan SYN (stealth SYN scan), une technique de scan TCP courante et discrète.
    - **Interprétation des résultats :** Nmap affichera une liste des ports TCP *ouverts*, *fermés*, ou *filtrés* sur la VM cible. Concentrez-vous sur la section "Ports" de la sortie Nmap. Pour chaque port ouvert, Nmap indique le numéro de port, le protocole (tcp), l'état (open), et le service (si Nmap peut l'identifier).
    - **Scan des ports UDP (optionnel, plus lent) :** Pour scanner aussi les ports UDP (en plus des ports TCP), utilisez l'option `-sU` :

        ```
        nmap -sS -sU adresse_ip_victime
        ```

        Attention : Les scans UDP peuvent être plus lents et moins fiables que les scans TCP.
    - **Scan des ports les plus courants (plus rapide) :** Pour un scan plus rapide, vous pouvez scanner seulement les ports les plus courants (souvent les 1000 premiers ports) :

        ```
        nmap --fast adresse_ip_victime
        ```

    - **Découverte de services et versions :** Pour essayer de détecter les versions des services qui tournent sur les ports ouverts, utilisez l'option `-sV` (version detection) :

        ```
        nmap -sV adresse_ip_victime
        ```

        Attention : La détection de version peut être plus intrusive et prendre plus de temps.
    - **Exercice :** Identifiez les ports TCP ouverts sur la VM Ubuntu, les services qui tournent sur ces ports (si Nmap les a détectés), et de comparer les résultats des différents types de scans (SYN, UDP, rapide, version detection).

Autres Outils Utiles (optionnel, à tester) :

- `netcat` **(ou** `nc`**) :** "Couteau suisse" du réseau. Peut être utilisé pour envoyer et recevoir des données sur le réseau, scanner des ports (TCP/UDP), écouter des connexions, etc. Très utile pour les tests réseau

rapides et la communication brute avec des services réseau. Exemple : pour un scan de ports TCP avec `netcat` :

```
```bash
nc -zv adresse_ip_cible port_debut-port_fin
```
```

- **`tcpdump` :** Analyseur de paquets en ligne de commande (version console de Wireshark). Très puissant pour la capture de trafic réseau directement dans le terminal, sans interface graphique. Utile pour les scripts et les serveurs sans GUI. Exemple : pour capturer seulement les paquets ICMP sur l'interface `eth0` :

```
```bash
sudo tcpdump -i eth0 -n icmp
```
```

Résolution de Problèmes :

- **Wireshark ne capture pas de trafic :**
  - Vérifiez que vous avez lancé Wireshark avec les privilèges administrateur (avec `sudo` si nécessaire). La capture de paquets requiert des droits élevés.
  - Vérifiez que vous avez sélectionné la bonne interface réseau dans Wireshark (celle qui est connectée au réseau interne).
  - Vérifiez que du trafic réseau est bien généré (avec `ping` ou d'autres outils).
- **Nmap ne trouve pas de ports ouverts :**
  - Vérifiez que l'adresse IP cible est correcte et que la VM cible est bien démarrée et connectée au réseau.
  - Vérifiez que le pare-feu de la VM cible (si activé) n'est pas en train de bloquer les scans Nmap. Pour les labs, il est souvent plus simple de désactiver les pare-feux pour éviter des complications inutiles.
  - Essayez différents types de scans Nmap (`-sS`, `-sT`, `-sU`, etc.) pour voir si cela change les résultats.

Partie 1E : Mise en place de protection basique (exemple : firewall basique)

Objectif : Introduction des concepts fondamentaux des firewalls et apprendre à configurer un firewall basique en ligne de commande sous Linux avec `iptables`. Vous comprendrez comment un firewall peut filtrer le trafic réseau et protéger un système en contrôlant les connexions entrantes et sortantes. Cette partie est une première étape essentielle pour comprendre la sécurité réseau défensive.

Firewall Basique avec `iptables` (Linux)

- **Rôle d'un Firewall :** Un firewall (pare-feu) est un système de sécurité réseau qui surveille et contrôle le trafic réseau entrant et sortant en fonction d'un ensemble de règles de sécurité. Il agit comme une

barrière de protection entre un réseau interne (votre VM) et un réseau externe (le réseau interne virtuel, ou potentiellement internet si vous utilisez un mode réseau différent). Un firewall peut :
    - **Autoriser** le trafic légitime.
    - **Bloquer** le trafic non autorisé ou potentiellement malveillant.
- **`iptables` : Le Firewall Linux en Ligne de Commande :** `iptables` est l'outil de firewall en ligne de commande traditionnel pour Linux (remplacé par `nftables` dans les versions plus récentes, mais `iptables` reste largement utilisé et pédagogique pour commencer). Il permet de définir des règles de filtrage basées sur divers critères (adresses IP source/destination, ports, protocoles, etc.).
- **Chaînes et Règles `iptables` :** `iptables` organise les règles en "chaînes" (chains). Les chaînes principales sont :
    - `INPUT` : Pour le trafic *entrant* vers la machine (destiné à la VM).
    - `OUTPUT` : Pour le trafic *sortant* de la machine (provenant de la VM).
    - `FORWARD` : Pour le trafic *transitant* par la machine (si la VM agissait comme un routeur, ce qui n'est pas le cas ici dans notre configuration basique).
- **Règles `iptables` :** Chaque règle dans une chaîne spécifie une action à prendre (ACCEPT, DROP, REJECT) pour le trafic qui correspond à certains critères. Les règles sont évaluées séquentiellement dans l'ordre de la chaîne.

Prise en Main :

1. **Vérification du Statut Actuel d'`iptables` (VM Ubuntu - Serveur) :**
    - Connectez-vous à votre VM **Ubuntu (serveur)**.
    - Ouvrez un terminal.
    - Affichez les règles `iptables` actuelles (au démarrage, il ne devrait pas y avoir de règles par défaut sur Ubuntu Server) :

      ```
      sudo iptables -L
      ```

      `-L` (list) affiche les règles de toutes les chaînes. Vous devriez voir des chaînes `INPUT`, `FORWARD`, `OUTPUT` avec des politiques par défaut (souvent `ACCEPT` ou `DROP`, selon la distribution) et aucune règle spécifique pour l'instant.

2. **Mise en Place d'une Règle de Firewall Basique : Bloquer le Ping (ICMP INPUT) :**
    - **Objectif :** Empêcher la VM Ubuntu de répondre aux requêtes Ping (ICMP Echo Request) *entrantes*. Cela signifie bloquer le trafic ICMP *entrant* dans la chaîne `INPUT`.
    - **Ajout de la règle `iptables` :** Exécutez la commande suivante sur la VM Ubuntu :

      ```
      sudo iptables -A INPUT -p icmp --icmp-type echo-request -j DROP
      ```

        - `-A INPUT` : Ajoute la règle à la *fin* de la chaîne `INPUT`.
        - `-p icmp` : Spécifie le protocole : ICMP.
        - `--icmp-type echo-request` : Spécifie le type ICMP : "echo-request" (les requêtes Ping).

    - `-j DROP` : Spécifie l'action ("jump") : `DROP`. `DROP` signifie que le paquet sera *silencieusement ignoré* (pas de réponse envoyée à l'expéditeur). Une alternative est `REJECT`, qui envoie un message d'erreur ICMP à l'expéditeur (plus "poli" mais peut révéler plus d'informations). Pour un blocage simple, `DROP` est souvent suffisant.
  - **Vérification de la règle ajoutée :** Ré-affichez les règles `iptables` :

    ```
    sudo iptables -L
    ```

    Vous devriez maintenant voir la nouvelle règle dans la chaîne `INPUT`.

3. **Test de la Règle : Ping depuis la VM Kali Linux (Client) vers la VM Ubuntu (Serveur `Exemple : VM Victime comme vu précédemment`) :**
  - Depuis la VM **Kali Linux (client `Exemple : VM Attaquant (testeur de ping) comme vu précédemment`)**, essayez de pinguer la VM **Ubuntu (serveur)**. Remplacez `adresse_ip_ubuntu` par l'adresse IP de la VM Ubuntu :

    ```
    ping adresse_ip_ubuntu
    ```

  - **Résultat attendu :** Les pings devraient *ne plus recevoir de réponse* (délai d'attente dépassé, "Request timeout"). Ceci confirme que la règle `iptables` sur la VM Ubuntu bloque bien les requêtes Ping entrantes.

4. **Autoriser le Trafic SSH Entrant (TCP INPUT port 22) :**
  - **Objectif :** Après avoir bloqué le Ping, nous voulons toujours pouvoir nous connecter à la VM Ubuntu en SSH (port 22 TCP). Il faut donc ajouter une règle pour *autoriser* le trafic SSH *entrant*. Il est important d'autoriser explicitement le trafic nécessaire après avoir mis en place un firewall restrictif.
  - **Ajout de la règle `iptables` pour SSH :** Exécutez la commande suivante sur la VM Ubuntu :

    ```
    sudo iptables -A INPUT -p tcp --dport 22 -j ACCEPT
    ```

    - `-A INPUT` : Ajoute à la chaîne `INPUT`.
    - `-p tcp` : Spécifie le protocole : TCP.
    - `--dport 22` : Spécifie le port de destination : 22 (port SSH standard).
    - `-j ACCEPT` : Spécifie l'action : `ACCEPT`. Autorise le trafic correspondant.
  - **Important : Ordre des règles :** L'ordre des règles dans `iptables` est *très important*. Les règles sont évaluées de haut en bas. Il est généralement conseillé de mettre les règles `ACCEPT` (autoriser) *avant* les règles `DROP` ou `REJECT` (bloquer). Dans notre cas, si la règle `DROP ICMP` était après la règle `ACCEPT SSH`, cela fonctionnerait toujours car les règles sont évaluées indépendamment pour chaque type de trafic (ICMP vs TCP). Mais pour des configurations plus complexes, l'ordre devient vital. Pour insérer une règle à une position spécifique (pas à la fin), on peut utiliser `-I` (insert) au lieu de `-A` (append) et spécifier un numéro de règle.

5. **Test de la Règle SSH : Connexion SSH depuis la VM Kali Linux (Client) vers la VM Ubuntu (Serveur) :**
    - Depuis la VM **Kali Linux (client)**, essayez de vous connecter en SSH à la VM **Ubuntu (serveur)** :

      ```
      ssh utilisateur@adresse_ip_ubuntu
      ```

      (remplacez `utilisateur` et `adresse_ip_ubuntu`).
    - **Résultat attendu :** La connexion SSH devrait *fonctionner*. Vous devriez pouvoir vous connecter à la VM Ubuntu en SSH, même si le Ping est toujours bloqué. Ceci démontre que le firewall filtre le trafic de manière sélective, en bloquant le Ping mais en autorisant SSH.

6. **Politique par Défaut de la Chaîne `INPUT` (Optionnel, pour aller plus loin) :**
    - **Politique actuelle :** Par défaut, la politique de la chaîne `INPUT` est souvent `ACCEPT` (ou `DROP` selon les distributions). Vous pouvez voir la politique par défaut en utilisant :

      ```
      sudo iptables -L -v
      ```

      La politique est indiquée en haut de chaque chaîne (ex: `Chain INPUT (policy ACCEPT)`).
    - **Modifier la politique par défaut en `DROP` (configuration plus sécurisée) :** Pour une sécurité accrue, on peut changer la politique par défaut de la chaîne `INPUT` en `DROP`. Cela signifie que *tout* trafic entrant qui ne correspond à *aucune* règle `ACCEPT` explicite sera *automatiquement bloqué*. *Attention : Faites ceci avec précaution et seulement après avoir configuré les règles `ACCEPT` nécessaires (comme SSH), sinon vous risquez de vous couper l'accès à votre propre VM.*

      ```
      sudo iptables -P INPUT DROP
      ```

      `-P INPUT DROP` : Définit la politique par défaut de la chaîne `INPUT` à `DROP`.
    - **Après avoir changé la politique par défaut en `DROP`, vous devrez explicitement autoriser *tout* le trafic entrant que vous souhaitez autoriser (SSH, HTTP, etc.) avec des règles `ACCEPT` spécifiques.** Si vous ne le faites pas, *tout* le trafic entrant sera bloqué par la politique par défaut. Pour cette partie introductive, il est peut-être plus simple de laisser la politique par défaut à `ACCEPT` et de juste ajouter des règles `DROP` spécifiques pour ce que vous voulez bloquer explicitement.

7. **Suppression des Règles `iptables` (Nettoyage) :**
    - Pour supprimer les règles `iptables` que vous avez ajoutées et revenir à une configuration par défaut, vous pouvez utiliser :
        - **Supprimer une règle spécifique par numéro :** Affichez les règles avec numéros de ligne :

          ```
          sudo iptables -L --line-numbers
          ```

Repérez le numéro de la règle à supprimer (ex: la règle `DROP ICMP` est la ligne 1). Supprimez-la avec :

```
sudo iptables -D INPUT <numéro_de_ligne>
```

(ex: `sudo iptables -D INPUT 1`).

- **Vider complètement une chaîne (supprimer toutes les règles d'une chaîne) :** Pour vider la chaîne `INPUT` de toutes ses règles :

```
sudo iptables -F INPUT
```

`-F` (flush) vide la chaîne spécifiée. Pour vider toutes les chaînes : `sudo iptables -F`.

- **Réinitialiser complètement `iptables` (vider toutes les chaînes et remettre les politiques par défaut) :** `sudo iptables -X` (supprime les chaînes définies par l'utilisateur, pas les chaînes par défaut), puis `sudo iptables -F`, puis :

```
sudo iptables -P INPUT ACCEPT
sudo iptables -P OUTPUT ACCEPT
sudo iptables -P FORWARD ACCEPT
```

(remet les politiques par défaut à `ACCEPT`). Une manière plus simple de tout réinitialiser est souvent de redémarrer la VM ou le service réseau, car la configuration `iptables` est souvent rechargée au démarrage depuis un fichier de configuration (selon la distribution).

Résolution de Problèmes :

- **Le firewall ne bloque pas le Ping :**
  - Vérifiez que vous avez bien exécuté la commande `iptables` avec `sudo`. La modification des règles de firewall requiert des privilèges administrateur.
  - Vérifiez la syntaxe de la commande `iptables`. Une erreur de syntaxe peut empêcher l'ajout de la règle.
  - Vérifiez avec `sudo iptables -L` que la règle a bien été ajoutée à la chaîne `INPUT`.
  - Vérifiez que vous pinguez bien la VM Ubuntu *depuis l'extérieur* (depuis la VM Kali ou une autre machine sur le réseau interne), et non depuis la VM Ubuntu elle-même. Le firewall `INPUT` filtre le trafic *entrant*.
- **Vous êtes coupé de votre VM en SSH après avoir modifié `iptables` :**
  - Si vous avez accidentellement bloqué le trafic SSH entrant (par exemple, en changeant la politique par défaut en `DROP` sans autoriser SSH), vous risquez de perdre la connexion SSH et de ne plus pouvoir accéder à la VM à distance. Si vous avez un accès direct à la console de la VM (via VirtualBox ou Parallels), vous pouvez essayer de vous connecter à la console et de modifier les règles `iptables` pour ré-autoriser SSH ou réinitialiser `iptables`. Si vous n'avez pas d'accès console, la seule option peut être de redémarrer la VM (en espérant que la configuration `iptables` par défaut au démarrage permette l'accès SSH, ou de restaurer un snapshot de la VM

si vous en avez un). *Ceci souligne l'importance de tester les règles de firewall avec précaution et de s'assurer de toujours maintenir un accès à la machine.*

END